

Đánh giá lỗ hổng (Vulnerability Assessment)

HTB Academy • Bản ghi chép hoàn chỉnh của mô-đun

Tổng quan mô-đun

- **Độ khó:** Dễ
- **Cấp:** Tier 0
- **Thời gian dự kiến:** 2 giờ
- **Lần cập nhật gần nhất được ghi nhận:** 4 năm trước
- **Cấu trúc:** 17 phần • 2 phần thực hành • 2 bài đánh giá
- **Kiến thức tiên quyết được đề cập:** Linux Fundamentals
- **Huy hiệu/Cubes:** 10 cubes

Mô tả

Mô-đun nhập môn về đánh giá lỗ hổng, sự khác biệt với kiểm thử xâm nhập (pentest), diễn giải kết quả, sử dụng [LAB_CREDENTIAL_REDACTED] và báo cáo phát hiện.

Tóm lược mô-đun

Mô-đun xây dựng nền tảng quản lý và ưu tiên lỗ hổng, giới thiệu các tiêu chuẩn, CVSS/CVE, so sánh trình quét, hướng dẫn cài đặt và vận hành thực tế Nessus, OpenVAS, rồi kết thúc bằng cấu trúc báo cáo chuyên nghiệp.

Danh sách các phần

- **Phần 01** — Đánh giá bảo mật
- **Phần 02** — Đánh giá lỗ hổng
- **Phần 03** — Các tiêu chuẩn đánh giá
- **Phần 04** — Hệ thống chấm điểm lỗ hổng phổ biến (CVSS)
- **Phần 05** — Các lỗ hổng và phơi nhiễm phổ biến (CVE)
- **Phần 06** — Tổng quan quét lỗ hổng
- **Phần 07** — Bắt đầu với Nessus
- **Phần 08** — Quét bằng Nessus
- **Phần 09** — Cài đặt nâng cao
- **Phần 10** — Xử lý kết quả quét Nessus
- **Phần 11** — Các vấn đề khi quét
- **Phần 12** — Bài đánh giá kỹ năng Nessus
- **Phần 13** — Bắt đầu với OpenVAS
- **Phần 14** — Quét bằng OpenVAS
- **Phần 15** — Xuất kết quả
- **Phần 16** — Bài đánh giá kỹ năng OpenVAS
- **Phần 17** — Viết báo cáo

Phần 01 — Đánh giá bảo mật

Tóm tắt lý thuyết

Đánh giá bảo mật là khái niệm bao trùm nhiều hình thức đánh giá an toàn của mạng, máy tính, ứng dụng và tài sản khác. Mục tiêu chung là tìm điểm yếu, giảm mức độ phơi nhiễm, định hướng khắc phục và hỗ trợ quyết định rủi ro theo mức trưởng thành, lĩnh vực và yêu cầu tuân thủ của tổ chức.

Phần này phân biệt đánh giá lỗ hổng với kiểm thử xâm nhập và cho thấy hai hoạt động bổ sung cho nhau. Đánh giá lỗ hổng tập trung nhận diện, phân loại lỗi đã biết với ít hoặc không khai thác thủ công; pentest tập trung khai thác có kiểm soát, tác động sát thực tế và kết hợp các lỗ hổng. Nội dung còn đề cập mô hình hộp đen, hộp xám, hộp trắng và các chuyên môn ứng dụng, mạng/hạ tầng, vật lý, kỹ nghệ xã hội.

Điểm chính

- Đánh giá bảo mật thay đổi theo rủi ro, ngân sách, quy định và mức trưởng thành của doanh nghiệp.
- Đánh giá lỗ hổng và pentest không đồng nghĩa: một bên nhận diện, ưu tiên; bên kia xác nhận khả năng khai thác và tác động thực tế.
- Hộp đen, xám, trắng thay đổi điểm xuất phát và lượng thông tin người đánh giá có được.
- Kiểm toán, bug bounty, red team và purple team là các mô hình bổ sung hữu ích trong bối cảnh riêng.

Điều cần ghi nhớ

Chọn loại đánh giá theo mục tiêu kinh doanh và mức trưởng thành của môi trường, không theo sở thích cá nhân của người kiểm thử.

Phần 02 — Đánh giá lỗ hổng

Tóm tắt lý thuyết

Đánh giá lỗ hổng tìm cách nhận diện, phân loại và ưu tiên rủi ro liên quan tới điểm yếu có thể quan sát trong môi trường, với ít hoặc không khai thác thủ công. Giá trị nằm ở tạo khả năng quan sát, bối cảnh và định hướng sửa lỗi, không phải mô phỏng kẻ tấn công tới cuối chuỗi.

Mô-đun đưa ra phương pháp tám bước: nhận diện rủi ro và tài sản, tạo chính sách quét, chọn loại quét, cấu hình trình quét, thực thi, đánh giá rủi ro vận hành do chính việc quét gây ra, diễn giải kết quả và xây dựng kế hoạch khắc phục/giảm thiểu. Phần này định nghĩa lỗ hổng, mối đe dọa, khai thác và rủi ro, đồng thời gắn hoạt động quét với quản lý tài sản và danh mục được cập nhật.

Điểm chính

- Trình quét chỉ là một phần; chính sách, bối cảnh, phân tích và khắc phục thuộc chu trình đầy đủ.
- Rủi ro phụ thuộc xác suất và tác động, không chỉ tên lỗ hổng.
- Kiểm kê tài sản là nền tảng của chương trình quản lý lỗ hổng nghiêm túc.
- Cần kiểm chứng bản vá trước khi triển khai sản xuất để tránh gián đoạn.

Điều cần ghi nhớ

Thiếu danh mục đáng tin cậy và ưu tiên rủi ro, đánh giá lỗ hổng chỉ thành danh sách phát hiện rời rạc, không có giá trị vận hành.

Phần 03 — Các tiêu chuẩn đánh giá

Tóm tắt lý thuyết

Pentest và đánh giá lỗ hổng cần theo tiêu chuẩn được chính phủ, kiểm toán viên và ngành chấp nhận. Tiêu chuẩn tạo tính nhất quán, giảm khả năng gây thiệt hại không cần thiết và giúp công việc có cơ sở bảo vệ về kỹ thuật lẫn hợp đồng.

Phần này tách tiêu chuẩn tuân thủ — PCI DSS, HIPAA, FISMA, ISO 27001 — khỏi tiêu chuẩn phương pháp kiểm thử như PTES, OSSTMM, NIST, OWASP. Tổ chức đáp ứng yêu cầu quy định và người kiểm thử dùng khuôn khổ có cấu trúc để đánh giá là hai vấn đề khác nhau.

Điểm chính

- PCI DSS nhấn mạnh bảo vệ môi trường dữ liệu chủ thẻ (CDE), yêu cầu quét nội bộ và bên ngoài.
- ISO 27001 phụ thuộc hệ thống quản lý an toàn thông tin (ISMS) trưởng thành; tuân thủ không chỉ là chạy trình quét.
- Pentest luôn cần phạm vi, ủy quyền chính thức, hợp đồng và quy tắc thực hiện.
- PTES, OSSTMM, NIST, OWASP giúp tổ chức kiểm thử theo cách có thể lặp lại.

Điều cần ghi nhớ

Tiêu chuẩn vừa định hướng thực hiện vừa chứng minh cuộc đánh giá có phương pháp, giới hạn và trách nhiệm.

Phần 04 — Hệ thống chấm điểm lỗ hổng phổ biến (CVSS)

Tóm tắt lý thuyết

CVSS là tiêu chuẩn được dùng rộng rãi nhất để đo mức nghiêm trọng của lỗ hổng và xuất hiện trực tiếp trong phần lớn trình quét. Điểm số không phải “phép màu”: nó hình thành từ các chỉ số xác định rõ, cần hiểu để giải thích và ưu tiên phát hiện có căn cứ.

Điểm được tổ chức thành ba nhóm: Cơ sở (Base), Thời gian (Temporal) và Môi trường (Environmental). Chỉ số cơ sở kết hợp khả năng khai thác và tác động; chỉ số thời gian xét mức hoàn thiện của mã khai thác, khả năng khắc phục và độ tin cậy báo cáo; chỉ số môi trường điều chỉnh mức quan trọng theo bối cảnh kinh doanh và trọng số bảo mật, toàn vẹn, sẵn sàng của tổ chức.

Điểm chính

- Khả năng khai thác xét hướng tấn công, độ phức tạp, đặc quyền cần có và tương tác người dùng.
- Tác động dùng bộ ba CIA: tính bảo mật, toàn vẹn, sẵn sàng.
- Mã khai thác công khai, bản vá sẵn có và độ tin cậy bằng chứng thay đổi mức khẩn cấp xử lý.
- Bối cảnh môi trường có thể tăng hoặc giảm ưu tiên thực tế của cùng một lỗi.

Điều cần ghi nhớ

CVSS giúp dùng ngôn ngữ chung của ngành nhưng không thay thế đánh giá rủi ro theo bối cảnh.

Phần 05 — Các lỗ hổng và phơi nhiễm phổ biến (CVE)

Tóm tắt lý thuyết

Phần này giới thiệu hai thành phần chính trong hệ sinh thái quản lý lỗ hổng: OVAL và CVE. OVAL là ngôn ngữ công khai dựa trên XML để mô tả trạng thái hệ thống, tuân thủ, kiểm kê và vá lỗi; CVE là mã định danh công khai chuẩn hóa cách tham chiếu lỗ hổng cụ thể.

Nội dung còn trình bày quy trình nhận CVE, vai trò nhà cung cấp và cơ quan cấp mã CVE (CNA), cùng tầm quan trọng của công bố có trách nhiệm. Mục đích là giải thích cách phát hiện từ quan sát kỹ thuật cục bộ trở thành lỗ hổng được công nhận công khai, truy vết và đối chiếu được bởi trình quét, cơ sở dữ liệu.

Điểm chính

- OVAL có thể mô tả lỗ hổng, tuân thủ, danh mục và trạng thái bản vá.
- CVE là mã công khai duy nhất để tham chiếu nhất quán một lỗi.
- Không phải vấn đề nào cũng tự động có CVE; quy trình có tiêu chí và quản trị.
- Công bố có trách nhiệm giảm nguy cơ khai thác trước khi sửa lỗi.

Điều cần ghi nhớ

OVAL giúp mô tả, kiểm tra; CVE giúp đặt tên, truyền đạt công khai.

Phần 06 — Tổng quan quét lỗ hổng

Tóm tắt lý thuyết

Quét lỗ hổng là sử dụng công cụ tự động nhận diện lỗ hổng tiềm năng hoặc đã biết trên máy, thiết bị, ứng dụng và dịch vụ. Trình quét tăng độ bao phủ, tốc độ nhưng không thay thế phân tích của con người trong pentest.

Phần này phân biệt kiểm tra tĩnh, chủ yếu dựa vào phiên bản và đối chiếu lỗ hổng đã biết, với kiểm tra động, cố xác nhận hành vi gọi ý lỗi qua kiểm tra có kiểm soát. Nội dung nhấn mạnh quét có và không xác thực trong hoạt động liên tục, đề cập Nessus, Qualys, Nexpose và OpenVAS.

Điểm chính

- Kiểm tra tĩnh mở rộng tốt nhưng dễ có dương tính giả hơn.
- Kiểm tra động tăng độ tin cậy qua xác minh hành vi, chưa tương đương khai thác đầy đủ.
- Quét có xác thực cho khả năng quan sát sâu hơn quét không xác thực.
- Quét liên tục cần cung cấp đầu vào cho quản lý bản vá và duy trì an toàn cơ bản của môi trường.

Điều cần ghi nhớ

Trình quét tốt không kết thúc công việc; nó tạo nền tảng tốt hơn cho phân tích, xác minh và khắc phục.

Phần 07 — Bắt đầu với Nessus

Tóm tắt lý thuyết

Nessus được giới thiệu như nền tảng quét có giao diện web và quy trình thiết lập tương đối đơn giản. Quy trình gồm tải gói phù hợp cho [LAB_CREDENTIAL_REDACTED], yêu cầu mã kích hoạt Nessus Essentials, cài gói, khởi động dịch vụ và hoàn tất thiết lập ban đầu trên web.

Sau kích hoạt, người dùng tạo tài khoản quản trị, chờ nạp/biên dịch plugin. Trong lab HTB, Nessus đã cài sẵn, truy cập qua cổng 8834; hiểu quá trình khởi tạo vẫn quan trọng khi dùng ngoài lab.

Điểm chính

- Nessus Essentials miễn phí nhưng cần mã kích hoạt.
- Giao diện chính ở cổng 8834.
- Plugin là phần thiết yếu của trình quét.
- Hiểu thiết lập và dịch vụ giúp xử lý sự cố ngay cả với môi trường có sẵn.

Điều cần ghi nhớ

Nessus là nền tảng đánh giá hoạt động lâu dài, không chỉ một lệnh riêng lẻ.

Phần 08 — Quét bằng Nessus

Tóm tắt lý thuyết

Tạo lượt quét bắt đầu ở New Scan, với mẫu thuộc các nhóm Discovery, Vulnerabilities, Compliance. Mẫu chính của mô-đun là Basic Network Scan, nhưng giá trị thực nằm ở điều chỉnh khám phá, cổng, dịch vụ và đánh giá.

Nội dung đi qua khám phá máy, lưu ý thiết bị dễ bị ảnh hưởng, cấu hình quét cổng, khám phá dịch vụ với SSL/TLS, tùy chọn quét ứng dụng web, dùng thông tin xác thực và kỹ thuật như liệt kê người dùng bằng thử RID. Trong Advanced, safe checks và tùy chọn hiệu năng cân bằng độ bao phủ với rủi ro vận hành.

Điểm chính

- Mẫu chỉ là điểm khởi đầu; mục tiêu và tình cảnh quan trọng hơn.
- Thiết bị dễ bị ảnh hưởng và dịch vụ nhạy cảm cần cấu hình cẩn thận.
- Khám phá dịch vụ không chỉ tìm cổng mở mà còn xác định thứ thực sự đang chạy.
- Kiểm tra an toàn và tình cảnh hiệu năng thiết yếu trong môi trường thực tế.

Điều cần ghi nhớ

Tăng mức mạnh bạo không luôn làm lượt quét tốt hơn; lượt quét tốt đạt mục tiêu với tác động thấp nhất có thể.

Phần 09 — Cài đặt nâng cao

Tóm tắt lý thuyết

Cài đặt nâng cao giúp Nessus chuyển từ dùng đơn lẻ sang vận hành định kỳ, chuẩn hóa. Phần này chủ yếu đề cập chính sách quét, nhóm plugin, quy tắc plugin và quét có xác thực.

Chính sách lưu cấu hình tái sử dụng; plugin NASL là trung tâm của các kiểm tra; quy tắc plugin giúp ẩn hoặc phân loại lại kết quả lặp lại gây nhiễu; quét với thông tin xác thực tăng đáng kể độ sâu đánh giá Linux, Windows, cơ sở dữ liệu và nhiều dịch vụ.

Điểm chính

- Mẫu là nền tảng; chính sách là cấu hình chuẩn hóa, tái sử dụng.
- Plugin thực hiện kiểm tra thực tế và có mức nghiêm trọng riêng.
- Quy tắc plugin giảm nhiễu nhưng không thay thế khắc phục thực sự.
- Quét có thông tin xác thực giảm dương tính giả, tăng hiểu biết về máy.

Điều cần ghi nhớ

Nessus có giá trị hơn nhiều khi chuẩn hóa chính sách, kiểm soát nhiều và dùng thông tin xác thực có cân nhắc.

Phần 10 — Xử lý kết quả quét Nessus

Tóm tắt lý thuyết

Nessus xuất PDF, HTML, CSV để người đọc sử dụng, cùng định dạng kỹ thuật `.nessus`, `.db` để lưu giữ, nhập lại, tự động hóa. Báo cáo thô của trình quét không nên là sản phẩm chính giao khách hàng, mà nên là phụ lục hoặc tài liệu bổ sung.

Mô-đun trình bày tự động xuất qua Nessus REST API bằng script `nessus-report-downloader`, cho thấy có thể vận hành quy trình báo cáo bằng CLI. EyeWitness được đề cập như hỗ trợ trực quan bổ sung khi phát hiện ứng dụng web.

Điểm chính

- PDF, HTML phù hợp đọc và xem chi tiết.
- CSV thuận tiện tích hợp, lọc, phân tích số lượng lớn.
- `.nessus`, `.db` lưu chi tiết kỹ thuật để sử dụng lại.
- API và tự động hóa hữu ích trong vận hành định kỳ.

Điều cần ghi nhớ

Xuất kết quả có mục đích quan trọng ngang với quét tốt.

Phần 11 — Các vấn đề khi quét

Tóm tắt lý thuyết

Quét lỗi hỏng có tác động vận hành. Trong môi trường nhạy cảm, đường truyền nghẽn, hệ thống cũ, tường lửa và thiết bị dễ bị ảnh hưởng có thể phản ứng xấu với lượt quét thiếu tinh chỉnh, gây dương tính giả hoặc gián đoạn.

Biện pháp giảm thiểu gồm tắt một số cách khám phá máy trong tình huống có vấn đề, giảm kiểm tra đồng thời, giữ safe checks, dành khung giờ riêng cho máy quan trọng và lưu log hoạt động chi tiết. vnstat minh họa tác động mạng bằng mức tăng thực tế của byte, gói tin khi quét.

Điểm chính

- Tường lửa có thể làm sai lệch khám phá máy và trạng thái cổng quan sát được.
- Giới hạn tốc độ, tinh chỉnh hiệu năng giảm rủi ro vận hành.
- Safe checks không loại bỏ mọi rủi ro nhưng giảm đáng kể tác động tiềm năng.
- Trao đổi với khách hàng/các bên liên quan và lưu log thuộc quy trình.

Điều cần ghi nhớ

Quét chuyên nghiệp cần kế hoạch vận hành, không chỉ kiến thức công cụ.

Phần 12 — Bài đánh giá kỹ năng Nessus

Tóm tắt lý thuyết

Bài thực hành đầu mô phỏng đánh giá lỗ hổng nội bộ trên Windows Server phát triển của Inlanefreight. Mục tiêu là cấu hình đúng quét có xác thực trong Nessus, mở rộng cổng và lấy phát hiện hỗ trợ đánh giá rủi ro ban đầu, không phải khai thác máy thủ công.

Bài tập củng cố Basic Network Scan, all ports, quét có xác thực, đọc phát hiện và ưu tiên bằng chứng hữu ích cho báo cáo ban đầu.

Điểm chính

- Trình quét: Nessus qua giao diện web.
- Loại quét: Basic Network Scan.
- Điều chỉnh bắt buộc: ALL ports (tất cả cổng).
- Có xác thực bằng tài khoản quản trị Windows.

Điều cần ghi nhớ

Bài này đo khả năng vận hành Nessus trong bối cảnh thực tế của đánh giá lỗ hổng nội bộ.

[Bài thực hành lab đã được lược bỏ khỏi bản công khai; xem module chính thức để tự thực hành.]

Phần 13 — Bắt đầu với OpenVAS

Tóm tắt lý thuyết

OpenVAS thuộc bộ Greenbone/GVM. Thiết lập cục bộ gồm cập nhật hệ thống, cài [LAB_CREDENTIAL_REDACTED], chạy gvm-setup, tạo chứng chỉ, chuẩn bị cơ sở dữ liệu, tạo tài khoản admin và đồng bộ feed/NVT.

Sau đó khởi động dịch vụ, giao diện ở cổng 9392. Tương tự Nessus, VM lab đã có công cụ sẵn, nhưng hiểu quá trình khởi tạo giúp vận hành ngoài môi trường dựng sẵn.

Điểm chính

- OpenVAS hỗ trợ quét có và không xác thực.
- Feed và NVT cập nhật thiết yếu cho giá trị trình quét.
- Thiết lập phức tạp hơn chỉ cài một gói.
- Giao diện web [LAB_CREDENTIAL_REDACTED] ở cổng 9392.

Điều cần ghi nhớ

OpenVAS là nền tảng đánh giá đầy đủ; trình quét chỉ là một thành phần hệ sinh thái Greenbone.

Phần 14 — Quét bằng OpenVAS

Tóm tắt lý thuyết

OpenVAS tổ chức vận hành theo mục tiêu (targets), cấu hình quét (scan configs), tác vụ (tasks). Trước khi tạo tác vụ, cần chuẩn bị mục tiêu trong Configuration: máy, cổng, phương pháp xác thực, phép kiểm tra máy còn hoạt động (alive test).

Phần này giới thiệu cấu hình dựa trên nhóm NVT như Host Discovery, Discovery, System Discovery, Base, Full and Fast. Full and Fast được nhấn mạnh là lựa chọn thực tế cho quét bao quát mà không cần cấu hình rủi ro hơn.

Điểm chính

- Target không chỉ là IP: còn lưu cổng, alive test, thông tin xác thực.
- Nhóm NVT là nền tảng chức năng của cấu hình quét.
- Host Discovery kiểm tra sự hiện diện; Full and Fast đánh giá đầy đủ hơn.
- Task = thực thi cụ thể tổ hợp target + config + scanner.

Điều cần ghi nhớ

Chuẩn bị mục tiêu tốt góp phần làm quét OpenVAS thành công.

Phần 15 — Xuất kết quả

Tóm tắt lý thuyết

Báo cáo OpenVAS xem trực tiếp trên giao diện theo các tab lỗ hổng, máy, cổng, ứng dụng, hệ điều hành, CVE, chứng chỉ TLS, thông báo lỗi. Nền tảng còn xuất XML, CSV, PDF, ITG, TXT.

XML là định dạng nền hữu ích cho phân tích cú pháp và xử lý tiếp. Với `openvasreporting`, báo cáo XML chuyển thành XLSX có tổng quan, biểu đồ, nhóm theo mức nghiêm trọng và nhóm lỗ hổng.

Điểm chính

- Giao diện cung cấp cách đọc phong phú theo máy, cổng, phát hiện.
- XML có giá trị nhất cho tự động hóa và chuyển đổi.
- XLSX thuận tiện cho đội nội bộ và theo dõi khắc phục.
- Xuất đúng cũng là một phần đánh giá.

Điều cần ghi nhớ

Kết quả tốt có thể được sử dụng, tái sử dụng và truyền đạt rõ ràng.

Phần 16 — Bài đánh giá kỹ năng OpenVAS

Tóm tắt lý thuyết

Bài thực hành thứ hai áp dụng OpenVAS vào đánh giá lỗ hổng nội bộ trên máy chủ Linux của Inlanefreight. Bài tập củng cố mục tiêu, tạo tác vụ, chọn trình quét, Full and Fast, thông tin xác thực.

Logic tương tự bài Nessus: cấu hình đúng, hiểu vai trò xác thực, lấy câu trả lời kỹ thuật từ báo cáo mà không biến thành pentest tấn công.

Điểm chính

- Trình quét: OpenVAS Default Scanner.
- Cấu hình: Full and Fast.
- Mục tiêu: máy Linux nội bộ.
- Có xác thực bằng tài khoản root.

Điều cần ghi nhớ

Bài này xác nhận khả năng vận hành OpenVAS trong quy trình quét có xác thực đầy đủ.

[Bài thực hành lab đã được lược bỏ khỏi bản công khai; xem module chính thức để tự thực hành.]

Phần 17 — Viết báo cáo

Tóm tắt lý thuyết

Phần cuối nhấn mạnh kỹ năng mềm và viết chuyên nghiệp là phần quan trọng của công việc bảo mật. Trình quét thiếu báo cáo hữu ích không mang lại giá trị thực cho khách hàng.

Cấu trúc tối thiểu được đề xuất cho sản phẩm đánh giá gồm Tóm tắt điều hành, Tổng quan đánh giá, Phạm vi và thời gian, Lỗi hổng và khuyến nghị. Cần xác minh thủ công phát hiện trước khi đưa vào báo cáo cuối, nhóm vấn đề hợp lý và viết rõ cho cả độc giả kỹ thuật lẫn không chuyên.

Điểm chính

- Tóm tắt điều hành phục vụ lãnh đạo và ưu tiên nhanh.
- Tổng quan ghi phương pháp, thời gian, công cụ.
- Phạm vi và thời gian tránh mơ hồ về những gì đã hoặc chưa kiểm thử.
- Mỗi phát hiện cần tên, CVE, CVSS, mô tả, tham chiếu, khắc phục, PoC, hệ thống ảnh hưởng.

Điều cần ghi nhớ

Báo cáo tốt phải rõ, ngắn gọn, có bối cảnh và có thể hành động theo.

Kết thúc mô-đun

Mô-đun hoàn thành chu trình đánh giá lỗ hổng: nền tảng và tiêu chuẩn, CVSS/CVE, vận hành trình quét thương mại và mã nguồn mở, xử lý nhiễu và tác động vận hành, cuối cùng giao kết quả chuyên nghiệp.

Nội dung ôn tập nhanh

- Đánh giá lỗ hổng và pentest bổ sung nhau nhưng không giống nhau.
- CVSS chuẩn hóa mức nghiêm trọng; CVE chuẩn hóa định danh công khai.
- Trình quét tăng tốc, độ bao phủ nhưng cần đọc có phê phán, xác minh, tinh chỉnh.
- Quét có xác thực tăng độ sâu, giảm dương tính giả.
- Nessus và OpenVAS là nền tảng vận hành liên tục, không chỉ công cụ dùng một lần.
- Báo cáo rõ và có thể hành động theo là phần thiết yếu, không phải bước phụ.

Ghi công: Ghi chép gốc của Gabriel Martorelli — kho nguồn

([https://\[LAB_CREDENTIAL_REDACTED\]/hack-the-box-academy-notes](https://[LAB_CREDENTIAL_REDACTED]/hack-the-box-academy-notes)). Đây là bản dịch tiếng Việt, không phải tài liệu chính thức của Hack The Box Academy. Xem `ATTRIBUTION.md` (`ATTRIBUTION.md`) và `LICENSE` (`LICENSE`).